

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this lecture you will be able to describe each phase of the cryptographic key lifecycle and explain why each phase matters for maintaining encryption integrity.
- By the end of this lecture you will be able to differentiate between provider-managed keys, customer-managed keys, BYOK, and HYOK and select the appropriate model based on data classification and sovereignty requirements.
- By the end of this lecture you will be able to explain what a Hardware Security Module (HSM) does and identify the FIPS 140-2 certification levels relevant to cloud key management services.
- By the end of this lecture you will be able to identify the most common key management failures and articulate the controls that prevent them.
- By the end of this lecture you will be able to apply key management decision criteria to CCSP examination scenarios involving data classification, regulatory requirements, and cloud control models.

Introduction

Strong encryption is only as strong as the keys protecting it. Organizations routinely invest in AES-256 encryption for data at rest and TLS for data in transit, yet undermine that investment by storing keys in environment variables, embedding them in source code, or allowing them to persist indefinitely without rotation. In Domain 2 of the CCSP examination, key management is treated as a foundational control discipline — not an operational afterthought — because the entire confidentiality guarantee of cloud-stored data rests on the quality of the key management programme.

The cryptographic key lifecycle provides a structured way to think about keys from creation through secure destruction. Each phase — generation, distribution, storage, rotation, revocation, and destruction — introduces distinct risk vectors that a practitioner must design controls around. Cloud providers have built dedicated services precisely to address the risks that arise when organizations manage keys informally: AWS Key Management Service, Azure Key Vault, and Google Cloud Key Management Service all centralise key operations behind audited APIs and HSM-backed storage, removing the need for applications to handle raw key material directly.

This lecture also addresses the spectrum of key control models, from provider-managed keys where the provider holds all operational authority, through customer-managed keys and Bring Your Own Key (BYOK), to Hold Your Own Key (HYOK) architectures where the master key never enters the provider's infrastructure. A precise understanding of what each model actually guarantees — and where the common misconceptions lie — is essential for both the examination and for advising stakeholders who equate key control with data sovereignty without understanding the technical distinctions.

Core Concepts Explained

Cryptographic Key Lifecycle

Definition: The structured set of phases a cryptographic key passes through from creation to secure destruction: generation, distribution, storage, rotation, revocation, and destruction. Each phase requires explicit controls to maintain the confidentiality and integrity guarantees the key is intended to provide.

Business relevance: Without deliberate lifecycle management, keys accumulate indefinitely, some generated years ago with unknown randomness quality, distributed through insecure channels, and never rotated. Auditors and regulators increasingly require documented key lifecycle policies as evidence of a functioning encryption programme. PCI DSS Requirement 3.7 mandates documented cryptographic key management procedures covering each lifecycle phase.

Cloud Security Practitioner relevance: A Cloud Security Practitioner must be able to assess whether each lifecycle phase has an associated control: generation quality, secure distribution mechanism, storage location relative to protected data, rotation schedule, documented revocation procedure, and verified destruction method.

Real-world example: A large financial services firm discovered during a PCI DSS audit that encryption keys for their cloud-hosted cardholder data environment had not been rotated in four years. The keys had been generated manually by a developer in 2020, stored in a shared team password vault alongside the database credentials they protected, and never included in any rotation schedule. The auditor flagged this as a critical finding under PCI DSS Requirement 3.7.4 (cryptographic key changes at the end of the defined cryptoperiod). The remediation required a full re-keying exercise — generating new keys via AWS KMS, re-encrypting all stored cardholder data, retiring the old keys, and implementing automated annual rotation going forward. The root cause was the absence of a documented lifecycle policy at the time of initial deployment.

Risks or limitations: Absent lifecycle controls, organizations carry keys of unknown origin indefinitely. A key that was quietly compromised months ago provides ongoing access to every piece of data it protects until rotation or revocation occurs. The best practice is to treat rotation as a hard operational requirement enforced by automation, not a discretionary maintenance task.

Hardware Security Module (HSM)

Definition: A physical or virtual dedicated hardware device designed to generate, store, and perform cryptographic operations with key material. The defining characteristic is that the key never leaves the HSM in plaintext — all operations requiring the key execute inside the module, and only the result (a ciphertext or a signature) is returned to the calling application.

Business relevance: HSMs underpin compliance with cryptographic hardware standards. FIPS 140-2 Level 2 requires, at minimum, tamper-evident seals and role-based authentication. Level 3 additionally requires physical tamper resistance that makes it extremely difficult to extract key material even with physical access to the device. Cloud provider managed key services — AWS KMS, Azure Key Vault, Google Cloud KMS — use shared HSM infrastructure certified to at least FIPS 140-2 Level 2 or 3. AWS CloudHSM and Azure Dedicated HSM provide dedicated hardware for tenants who need single-tenant HSM isolation for regulatory or contractual reasons.

Cloud Security Practitioner relevance: A Cloud Security Practitioner assessing a key management architecture must verify that key material is stored in HSM-backed infrastructure, identify the FIPS 140-2 certification level of that infrastructure, and determine whether shared or dedicated HSM tenancy is required by the organization's regulatory context.

Real-world example: A healthcare organisation processing electronic protected health information (ePHI) under HIPAA migrated to Azure. Their legal counsel determined that HIPAA's addressable implementation specification for encryption required them to demonstrate that encryption key material was protected against insider access at the cloud provider. The organisation selected Azure Dedicated HSM, provisioning a single-tenant HSM appliance in Azure's West US 2 region. Under this model, Microsoft personnel have no logical access to the key material inside the HSM — only the organisation's designated administrators can authenticate to the module. During a subsequent HIPAA audit, the organisation produced the HSM's FIPS 140-2 Level 3 certification and a configuration document showing that administrative access required dual-person authentication, satisfying the auditor's inquiry about key material protection.

Risks or limitations: Storing encryption keys in the same storage system as the data they protect — even in encrypted form — collapses the separation of keys and ciphertext that encryption is designed to provide. The best practice is to treat key storage and data storage as categorically distinct systems, with HSM-backed key storage being the standard for any key protecting sensitive or regulated data.

Key Rotation

Definition: The process of generating a new cryptographic key to replace an existing one, re-encrypting any data protected by the old key under the new key, and retiring the old key in a way that limits but does not immediately destroy its availability for decrypting previously encrypted data that has not yet been migrated.

Business relevance: Rotation is the control that limits the blast radius of an undetected key compromise. If a key is quietly exfiltrated and no rotation ever occurs, the attacker has permanent access to every record that key ever protected. A monthly rotation schedule means that a compromised key provides access to at most one month of data before the next rotation renders it useless. Many compliance frameworks impose maximum key lifespans: NIST SP 800-57 defines cryptoperiods for different key types, and PCI DSS Requirement 3.7.4 mandates cryptographic key changes at the end of the defined cryptoperiod.

Cloud Security Practitioner relevance: A Cloud Security Practitioner must ensure that rotation schedules are defined in key management policy, enforced by automation (not manual process), and logged with evidence that each rotation completed successfully. AWS KMS supports automatic annual rotation for customer-managed keys. For shorter rotation intervals or for non-KMS key types, a rotation schedule implemented through infrastructure-as-code or a secrets management platform is required.

Real-world example: A software-as-a-service provider operating under a customer contract requiring SOC 2 Type II compliance configured automatic annual rotation for all customer-managed keys in AWS KMS managing their multi-tenant database encryption. However, their internal audit during a SOC 2 readiness review identified that the database encryption key used by their oldest customer environment — created in 2019 — had not been enrolled in the automatic rotation policy. It had been manually created before the organisation's KMS governance baseline was implemented and simply never included in the policy. The security team enrolled the key in automatic rotation, triggered an immediate manual rotation to address the gap period, and implemented a quarterly KMS key inventory check using AWS Config rules to alert on any customer-managed key with a last-rotation date older than 13 months.

Risks or limitations: Rotation scheduled but never verified is common. Keys may fail to rotate due to permission errors, resource conflicts, or policy gaps. The best practice is to combine automated rotation with automated alerting when rotation does not complete within the expected window.

Customer Control Models: CMK, BYOK, and HYOK

Definition: Three progressive levels of customer control over encryption key material in cloud environments. Customer-Managed Keys (CMK) give the customer control over access policy and rotation for keys held within

the provider's infrastructure. Bring Your Own Key (BYOK) allows the customer to generate key material externally and import it into the provider's key management service. Hold Your Own Key (HYOK) keeps the master key outside the provider's infrastructure entirely, requiring cloud services to call out to the customer's own key server for decryption capability.

Business relevance: Key control model selection directly affects data sovereignty, regulatory compliance, and incident response capability. A customer can disable or delete a CMK to immediately and irreversibly block decryption across all services using it — an effective kill switch for data access. BYOK provides auditability of key origin but does not prevent the provider from accessing key material once imported. HYOK is the only model where the provider is genuinely incapable of decrypting the data without the customer's active participation.

Cloud Security Practitioner relevance: A Cloud Security Practitioner advising on key control model selection must distinguish what each model technically guarantees. The most common error is advising stakeholders that BYOK satisfies data sovereignty requirements when it does not, because the key material enters the provider's HSM infrastructure upon import. Genuine data sovereignty with encryption typically requires HYOK or a fully external key management architecture.

Real-world example: A European multinational with operations subject to GDPR and national data protection laws was evaluating cloud storage for its mergers and acquisitions due diligence documents — among the most sensitive intellectual property the organisation held. The initial proposal from its cloud team was BYOK with AWS KMS, marketed internally as giving the organisation full key ownership. The organisation's data protection officer reviewed the model and noted that AWS KMS BYOK documentation explicitly states that imported key material enters AWS HSM infrastructure and that AWS maintains operational control of the HSMs. The DPO concluded that a national security letter or equivalent compulsory process could compel AWS to produce decryption capability without the organisation's knowledge. The organisation ultimately deployed an HYOK architecture using Thales CipherTrust Manager hosted in its own data centre. Decryption requests from AWS services route to the Thales appliance, which the organisation controls. AWS holds only ciphertext and has no autonomous decryption capability.

Risks or limitations: HYOK introduces operational complexity and a potential single point of failure: if the customer's key server is unavailable, no decryption occurs for affected services. The best practice for HYOK deployments is a highly available, geographically redundant key server cluster with documented failover procedures and regular failover testing.

Key Revocation and Secure Destruction

Definition: Key revocation is the immediate suspension of a key's authority to decrypt data, triggered upon confirmed or suspected compromise. Secure destruction is the irreversible elimination of key material such that forensic recovery is computationally infeasible, typically achieved in HSMs by zeroing key slots and verifying the zero state before the key is logged as destroyed.

Business relevance: Revocation is the incident response control for key compromise events. A key management system that cannot propagate immediate revocation across all dependent services leaves a window during which a compromised key continues to provide access. For cloud deployments using provider-managed key services, revocation and destruction of a customer-managed key immediately renders all data protected by that key unreadable — including to the provider. This capability is sometimes called cryptographic shredding and is used as a data disposal technique when physical media deletion is not verifiable.

Cloud Security Practitioner relevance: A Cloud Security Practitioner must ensure that revocation procedures are documented, tested, and capable of reaching all services dependent on the affected key without manual coordination delays. Cryptographic shredding as a data disposal method should be evaluated against regulatory

requirements: some frameworks require physical destruction evidence, others accept documented key destruction as equivalent.

Real-world example: A cloud-native financial technology company stored customer transaction history in Amazon S3 encrypted with a customer-managed key in AWS KMS. When offboarding a customer who requested complete data deletion under GDPR's right to erasure, the company needed to demonstrate that the data was irrecoverable without physically deleting multi-terabyte objects distributed across S3. Instead, the company's data governance team scheduled deletion of the customer's dedicated KMS key, which immediately made all S3 objects encrypted under that key unreadable. They retained an audit log from AWS CloudTrail showing the key deletion event with timestamp and requester identity. They provided this log as evidence of erasure to the customer's legal team, who confirmed it satisfied their GDPR Article 17 obligation. The approach avoided costly physical deletion operations while providing legally defensible evidence of irrecoverable data elimination.

Risks or limitations: Key deletion in AWS KMS has a mandatory 7-to-30-day waiting period to prevent accidental destruction. This waiting period is both a safeguard and a procedural consideration: revocation (disabling the key) takes effect immediately, but destruction is delayed. The best practice is to disable the key immediately upon a confirmed compromise or erasure obligation and then schedule deletion, treating the disable event as the effective revocation timestamp for compliance documentation.

Practical Applications

The following scenarios illustrate how key management principles apply to real cloud security decisions encountered by practitioners in enterprise, healthcare, and regulated financial environments.

Designing a Key Management Architecture for a Regulated Data Platform

A Cloud Security Practitioner at a healthcare organisation is designing the key management architecture for a new cloud-hosted data analytics platform that will process de-identified patient data alongside a smaller volume of identifiable ePHI for quality reporting. The practitioner begins by classifying the data: identifiable ePHI requires the highest level of key control; de-identified data warrants standard protection. For the ePHI analytics module, the practitioner recommends AWS CloudHSM with dedicated hardware tenancy to satisfy the organisation's HIPAA encryption implementation specification and its internal policy requiring FIPS 140-2 Level 3 key storage. For the de-identified data layer, standard AWS KMS customer-managed keys with automatic annual rotation are sufficient. The practitioner also specifies that application services must retrieve keys at runtime through the KMS API — no key material is to be embedded in application configuration, environment variables, or container images. The architecture is documented in the organisation's security design review and becomes the approved pattern for all subsequent data platform deployments. The key best practice this scenario illustrates is matching key control model to data classification rather than applying a single model uniformly across all data categories.

Investigating a Suspected Key Exposure Event

A security analyst at a cloud-first retail company receives an alert from their cloud-native secret scanning tool: a developer has committed code to a public GitHub repository containing what appears to be an AWS KMS key ID and an AWS access key pair. The analyst immediately initiates incident response. The AWS KMS key ID itself is not sensitive — it is a reference, not the key material — but the access key pair can be used to call the KMS API if the attached IAM policy permits KMS operations on that key. The analyst rotates the compromised IAM access key pair, disabling the old credentials immediately. They then review AWS CloudTrail for any API calls made using the exposed credentials in the hours between the commit and the rotation. CloudTrail shows no KMS decrypt

calls using the exposed credentials during that window. The analyst also reviews the KMS key policy to confirm that the compromised IAM identity's permissions were scoped to specific key operations only and did not include CreateKey or ScheduleKeyDeletion, limiting the potential impact. A lessons-learned note is added to the company's key management policy: KMS key IDs must not be committed to version control because their presence, combined with any associated credentials, represents an attack surface. Pre-commit hooks are configured to block commits containing patterns matching KMS key ID formats.

Evaluating BYOK versus HYOK for a Data Sovereignty Requirement

A Cloud Security Practitioner is advising a government-adjacent research organisation that processes controlled unclassified information (CUI) under NIST SP 800-171. The organisation's leadership has asked whether BYOK in Azure Key Vault will satisfy their requirement that encryption keys for CUI must remain under exclusive US government-cleared control and must not be accessible to foreign-controlled entities or commercial cloud provider employees. The practitioner reviews Microsoft's BYOK documentation, which confirms that key material imported into Azure Key Vault enters Microsoft's HSM infrastructure under Microsoft's operational control. The practitioner advises that BYOK does not satisfy the stated requirement because Microsoft personnel with appropriate access could theoretically access the key material. The practitioner recommends Azure Dedicated HSM with dual-person administrative access controlled by cleared personnel, combined with an HYOK architecture where the master encryption key resides on an on-premises HSM located within the organisation's security perimeter. The practitioner documents this recommendation with reference to NIST SP 800-171 Requirement 3.13.10 (employ cryptographic mechanisms to protect the confidentiality of CUI during transmission) and an organisation-specific interpretation that extends equivalent protection to data at rest. The recommendation is adopted, and the architecture is included in the organisation's System Security Plan.

Best Practices

- **Never store key material adjacent to the data it protects.** The key and the ciphertext must live in categorically separate systems. An encrypted database stored in the same bucket or storage account as its KMS key reference is not a problem, but an encrypted database stored alongside the plaintext key material or in a system that caches key material locally is a critical design error. Verify separation in architecture reviews by tracing where key material resides at rest.
- **Enforce key rotation through automation, not calendar reminders.** Manual rotation processes fail silently: the reminder is missed, the rotation is skipped, and no one knows. Configure automatic rotation in your key management service where the platform supports it (AWS KMS automatic annual rotation for CMKs), and implement automated alerting using AWS Config or Azure Policy to flag any key whose last rotation date exceeds the organisation's defined maximum cryptoperiod.
- **Apply the BYOK / HYOK distinction explicitly in data sovereignty assessments.** Do not allow stakeholders to conflate 'we generated the key' with 'the provider cannot access the key.' In every data sovereignty assessment involving encryption, document explicitly which party has the technical capability to decrypt the data. If the answer is 'both us and the provider,' BYOK is the model in use regardless of the label. If the requirement is genuine external control, HYOK is the minimum acceptable architecture.
- **Scope KMS key policies to the minimum necessary operations and callers.** KMS key policies that grant kms:* to broad IAM principals create unnecessary risk. Every key policy should enumerate the specific operations (kms:Decrypt, kms:GenerateDataKey) and the specific IAM roles or service principals permitted to invoke them. Audit key policies quarterly using AWS IAM Access Analyzer or equivalent to identify overly permissive grants.

- **Use cryptographic shredding as a documented data disposal method where physical deletion is impractical.** For data stored in cloud object storage, cryptographic shredding — deleting the KMS key protecting the data — is a legally recognised data disposal technique under GDPR and similar frameworks when paired with documented audit logs from the key management service showing the key deletion event with timestamp and identity. Establish this procedure in the organisation's data disposal standard before it is needed in an incident, not during one.

Common Mistakes and Misconceptions

Misconception: Treating BYOK as equivalent to data sovereignty, assuming the cloud provider cannot access data protected by an imported key.

Correct approach: BYOK imports key material into the provider's HSM infrastructure, giving the provider operational access to the key. Genuine data sovereignty with encryption requires HYOK, where the master key never enters the provider's systems. Document the technical distinction explicitly in any data sovereignty assessment.

Misconception: Embedding encryption keys in application configuration files, environment variables, or container images.

Correct approach: Applications should retrieve keys at runtime through authenticated API calls to a centralised key management service. The key is never stored locally. This is the primary design principle behind services like AWS KMS, Azure Key Vault, and HashiCorp Vault — they exist to eliminate the need for applications to handle raw key material.

Misconception: Skipping key rotation because re-encrypting large datasets is operationally inconvenient.

Correct approach: Most cloud key management services support envelope encryption, where a data encryption key (DEK) encrypts the actual data and a key encryption key (KEK) stored in the KMS encrypts the DEK. Rotating the KEK in the KMS does not require re-encrypting all data — only the DEK wrappers are updated. This dramatically reduces the operational cost of rotation.

Misconception: Assuming FIPS 140-2 certification on a cloud key management service means the customer's key material is inaccessible to provider personnel.

Correct approach: FIPS 140-2 certifies the cryptographic module's security properties — tamper resistance, authentication requirements, key management within the module. It does not restrict which parties have administrative access to the certified infrastructure. Provider personnel with appropriate privileges can still perform operations on keys in a FIPS 140-2 certified service unless the architecture specifically prevents it (as in dedicated HSM tenancy with customer-controlled authentication).

table: Cloud Key Control Model Decision Matrix

Use this matrix to select the appropriate key control model based on regulatory requirement, data sensitivity, and acceptable operational complexity.

Control Model	Key Material Location	Provider Decryption Capability	Best For	Operational Complexity
Provider-Managed Keys	Provider HSM (provider-generated)	Yes	General commercial data; low sensitivity; highest convenience	Low

Customer-Managed Keys (CMK)	Provider HSM (provider-generated)	Yes (with key policy permission)	Regulated data needing audit trail and kill-switch control	Medium
Bring Your Own Key (BYOK)	Provider HSM (customer-generated, imported)	Yes (once imported)	Key origin auditability; does NOT provide sovereignty	Medium-High
Hold Your Own Key (HYOK)	Customer-controlled HSM (never enters provider)	No	Strict data sovereignty; CUI; highest-sensitivity IP	High

How to use this: For any requirement stated as 'the provider must not be able to decrypt our data,' HYOK is the minimum acceptable architecture. BYOK satisfies key origin auditability, not provider exclusion.

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. An organisation's compliance team states that their cloud encryption keys must be generated by the organisation itself and must not be accessible to cloud provider personnel under any circumstances. Which key control model satisfies this requirement?

- A) A. Provider-managed keys using the cloud provider's default key management service
- B) B. Customer-managed keys (CMK) created within the cloud provider's key management service
- C) C. Bring Your Own Key (BYOK) with key material imported into the provider's key management service
- D) D. Hold Your Own Key (HYOK) with the master key retained on the organisation's own HSM infrastructure

Answer: D. Hold Your Own Key (HYOK) with the master key retained on the organisation's own HSM infrastructure

Q2. A cloud security practitioner is reviewing an architecture where an AWS S3 bucket stores encrypted database backups and the KMS customer-managed key used to encrypt those backups is referenced in a configuration file stored in the same S3 bucket. What is the primary security risk in this design?

- A) A. The configuration file format may not be compatible with future KMS key versions
- B) B. The key reference and the ciphertext are co-located, meaning access to the bucket provides access to everything needed to decrypt the data
- C) C. Storing a KMS key ID in a configuration file violates FIPS 140-2 requirements
- D) D. AWS KMS does not support configuration file references for customer-managed keys

Answer: B. The key reference and the ciphertext are co-located, meaning access to the bucket provides access to everything needed to decrypt the data

Q3. According to FIPS 140-2, what additional security requirement does Level 3 certification impose on a cryptographic module compared to Level 2?

- A) A. Level 3 requires that the module be hosted on dedicated hardware not shared with other cloud tenants
- B) B. Level 3 requires physical tamper resistance and identity-based authentication before any key operation, beyond Level 2's tamper-evident seals
- C) C. Level 3 requires that all key operations be logged to an immutable external audit system
- D) D. Level 3 requires that key material be rotated at least annually

Answer: B. Level 3 requires physical tamper resistance and identity-based authentication before any key operation, beyond Level 2's tamper-evident seals

Q4. A cloud security team discovers that an encryption key used for a production database has not been rotated in three years. The team wants to perform a rotation but is concerned about the operational cost of re-encrypting a 50-terabyte dataset. Which architectural approach allows the key to be rotated without re-encrypting the underlying data?

- A) A. Export the key from the KMS, rotate it manually, and re-import the new version
- B) B. Use envelope encryption, where rotating the key encryption key (KEK) in the KMS updates only the DEK wrappers without re-encrypting the data itself
- C) C. Disable the old key and create a new key, leaving the old data encrypted under the old key indefinitely
- D) D. Apply dynamic data masking to the database to avoid the need for key rotation

Answer: B. Use envelope encryption, where rotating the key encryption key (KEK) in the KMS updates only the DEK wrappers without re-encrypting the data itself

Q5. Which phase of the cryptographic key lifecycle is most directly associated with the risk of 'silent compromise providing indefinite attacker access'?

- A) A. Generation, because weak randomness produces predictable key material
- B) B. Distribution, because keys travelling through insecure channels can be intercepted
- C) C. Rotation, because the absence of rotation means a compromised key provides access indefinitely
- D) D. Destruction, because improperly destroyed keys can be forensically recovered

Answer: C. Rotation, because the absence of rotation means a compromised key provides access indefinitely

Reflection Questions

1. Consider the encryption keys currently used in your organisation's cloud environment. Do you know when each was generated, how it was distributed to the services using it, and whether it has ever been rotated?
2. If you had to disable every encryption key protecting a specific customer's data immediately — in response to a legal hold, a breach, or a customer erasure request — how long would that take, and how confident are you that the action would propagate to every dependent service?
3. What does your organisation's key management policy say about maximum key lifespans and rotation schedules? Is the policy enforced by automation or by manual process?
4. For your most sensitive data category, what key control model is in use? Has anyone formally assessed whether that model satisfies the data sovereignty requirements your stakeholders believe it satisfies?
5. Think about a scenario where a cloud provider employee needed to decrypt your organisation's data without your knowledge. What would prevent them? Is your answer grounded in the technical architecture, or in policy and contractual controls only?

Key Takeaways

- Key management is the practical foundation of encryption security — algorithm choices mean nothing if key lifecycle controls are absent.
- The cryptographic key lifecycle has six distinct phases: generation, distribution, storage, rotation, revocation, and destruction. Each phase requires explicit controls.

- Hardware Security Modules (HSMs) keep key material inside the device; only the results of cryptographic operations leave the HSM in plaintext.
- FIPS 140-2 Level 2 requires tamper-evident seals and role-based authentication; Level 3 adds physical tamper resistance and identity-based authentication.
- Customer-managed keys give operational control (access policy, rotation, kill-switch) but key material still resides in the provider's HSM infrastructure.
- BYOK provides auditability of key origin but does not prevent provider access to key material once imported — it does not satisfy data sovereignty requirements on its own.
- HYOK is the only model where the master key never enters the provider's infrastructure and the provider has no autonomous decryption capability.
- Cryptographic shredding — deleting the KMS key — is a legally recognised data disposal technique for cloud object storage when paired with audit log evidence.

Recommended Next Actions

Put this lecture to work within the next seven days:

6. Inventory all customer-managed keys in your cloud environment and verify that each has a documented rotation schedule and last-rotation date within the organisation's defined cryptoperiod. Use AWS Config or Azure Policy to automate this check.
7. Review one high-sensitivity data asset's key management architecture and document which party — customer or provider — has the technical capability to decrypt the data. If the answer does not match the data sovereignty requirement, escalate for architecture review.
8. Locate your organisation's data disposal procedure and confirm whether cryptographic shredding is listed as an accepted method. If not, draft a proposed addition with reference to the KMS audit log as evidence of destruction.